

FINAL TECHNICAL REPORT (LAPORAN AKHIR TEKNIS)

IPB SPACE: CAMPUS FACILITY & QUEUE SYSTEM

**DOKUMEN KOMPILASI IMPLEMENTASI KEAMANAN BERLAPIS, MANAJEMEN
KRIPTOGRAFI DATA AT REST, DAN PANDUAN OPERASIONAL PRODUKSI CLOUD**



Disusun Oleh (Kelompok 4 - Paralel 1):

- | | |
|---------------------------|---------------|
| 1. Naufal Ghifari Afdhala | (G6401231029) |
| 2. Samuel Christian | (G6401231037) |
| 3. Muhammad Farhadh | (G6401231080) |

**DEPARTEMEN ILMU KOMPUTER
SEKOLAH SAINS DATA, MATEMATIKA, DAN INFORMATIKA
INSTITUT PERTANIAN BOGOR
BOGOR
2026**

INFORMASI DOKUMEN DAN PARAMETER TEKNIS IMPLEMENTASI AKHIR

Parameter Sistem	Detail Spesifikasi Rekayasa Produk Akhir Kelompok 04
Mata Kuliah	KOM1315 Keamanan Informasi (Project-Based Learning Terintegrasi)
Nama Dokumen Luaran	Final_Technical_Report.pdf (Dokumen Kompilasi & User Manual Akhir)
Lokasi Target Folder	/04_Reports&Paper/ Final_Technical_Report/Final_Technical_Report.pdf
Format Nama Repositori	KOM1315_SmtGenap26_Kelompok04_IPBSpace
Tautan Kode Sumber Git	github.com/ nghifaria/KOM1315_SmtGenap26_Kelompok04_IPBSpace
Tautan Aplikasi (Live Production)	kom-1315-smt-genap26-kelompok04-ipb.vercel.app
Kredensial Akun Pengujian	• Super Admin: admin@ipbspace.com (Password: Admin1234) • Facility Manager: manager@ipbspace.com (Password: Manager1234) • Civitas (Mahasiswa): civitas@ipbspace.com (Password: Civitas1234)
Lapis Pengerasan Keamanan	Column-Level Encryption (AES-256-GCM), RSASSA-PSS 2048-bit Signature, stateless Bearer JWT, Bcrypt 12 Rounds Hashing, dan Parameterized PostgreSQL Queries Control

Daftar Isi

BAB 1: RINGKASAN EKSEKUSI PROYEK AKHIR	4
1.1 Latar Belakang Masalah	4
1.2 Tujuan Final Release Produk	4
1.3 Ruang Lingkup Implementasi Nyata	4
BAB 2: STRUKTUR IMPLEMENTASI DAN TOPOLOGI KODE	6
2.1 Struktur Kompilasi Repositori Git Akhir	6
2.2 Arsitektur Modular Komponen Backend (FastAPI App Stack)	6
2.3 Arsitektur Modular Komponen Frontend (React 19 UI Stack)	6
BAB 3: IMPLEMENTASI perlindungan DAN PENGENTASAN KEAMANAN SISTEM	7
3.1 Kontrol Keamanan Autentikasi (Authentication Layer)	7
3.2 Kontrol Otorisasi dan Pembatasan Hak Akses (Authorization Layer)	7
3.3 Protokol Akuntansi dan Audit Forensik (Accounting Layer)	7
3.4 Perlindungan Data Diam (Data at Rest) dan Tanda Tangan Digital (Digital Signature)	7
BAB 4: ALUR UTAMA DAN LOGIKA BISNIS APLIKASI	9
4.1 Registrasi, Login Multi-Peran, dan Validasi Payload	9
4.2 Kalender Jadwal Dinamis dan Penanganan Konflik Konkuren (Concurrency Guard)	9
4.3 Pengajuan Booking, Unggah Berkas, dan Validasi Sandbox Operator	9
4.4 Otorisasi Persetujuan Berkas dan Penandatanganan Tiket Otomatis	10
4.5 Pemindaian Check-In Lapangan dan Validasi Offline-Capable	10
BAB 5: KETERBATASAN SISTEM DAN REKOMENDASI PENINGKATAN	11
BAB 6: PANDUAN INSTALASI DAN OPERASIONAL INFRASTRUKTUR	12
6.1 Prasyarat Minimum Sistem (System Requirements)	12
6.2 Menjalankan Aplikasi via Docker Container (Direkomendasikan)	12

BAB 1: RINGKASAN EKSEKUSI PROYEK AKHIR

1.1 Latar Belakang Masalah

Mekanisme tata kelola peminjaman sarana prasarana fisik di lingkungan Institut Pertanian Bogor (IPB) sebelumnya dihadapkan pada kendala birokrasi manual yang panjang, tidak adanya transparansi ketersediaan ruangan secara dinamis, risiko terjadinya bentrok jadwal ganda (*overlapping booking*), serta kerentanan keamanan informasi kritis seperti pemalsuan surat izin fisik dan penolakan keputusan persetujuan operasional harian.

Platform **IPB Space** hadir sebagai solusi sistem informasi berbasis web terintegrasi yang menyajikan katalog fasilitas dan kalender jadwal pemakaian ruangan secara *real-time*. Dengan berfokus pada pilar Keamanan Informasi, IPB Space mengimplementasikan prinsip **Security by Design** melalui penancapan kontrol akses ketat menggunakan kerangka kerja **Authentication, Authorization, dan Accounting** (Protokol AAA), metode pengaburan data at rest tingkat kolom (**Column-Level Encryption AES-256-GCM**) untuk melindungi privasi data profil pengguna, serta penjaminan integritas transaksi peminjaman menggunakan tanda tangan digital kriptografi asimetris (**Digital Signature RSA-PSS**).

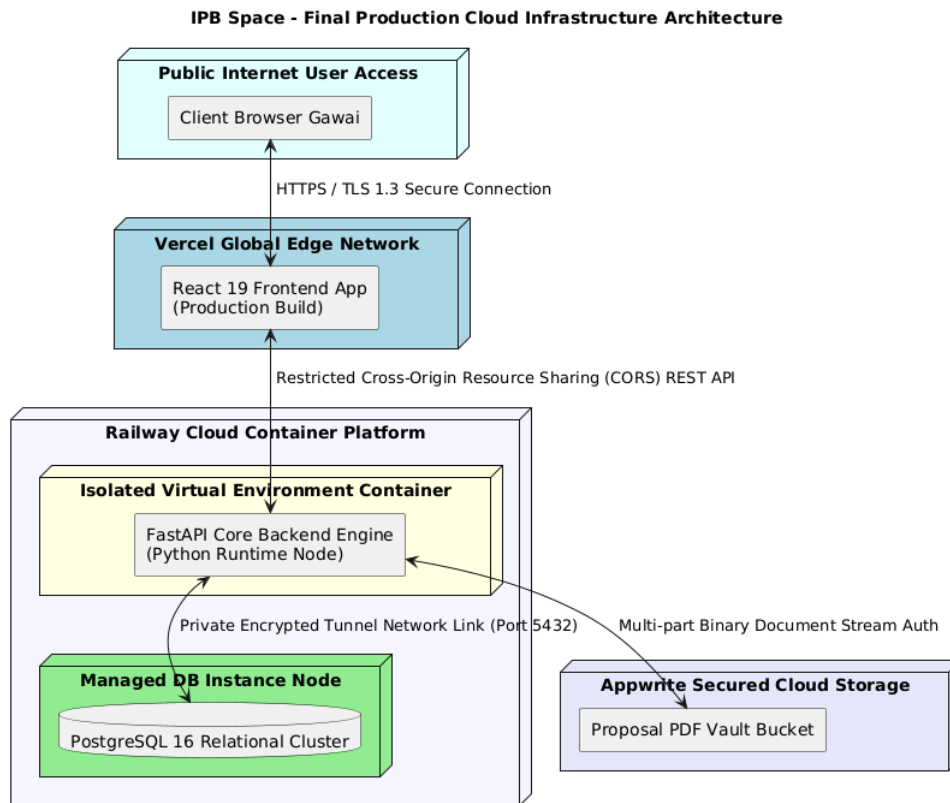
1.2 Tujuan Final Release Produk

Rilis produk teknis akhir ini mengompilasi seluruh kemajuan fungsional dan lapis pertahanan sistem IPB Space, meliputi:

1. Penyatuan kompilasi seluruh arsitektur kode sumber backend FastAPI, frontend React 19, dan kluster database relasional PostgreSQL.
2. Penegakan kontrol privasi data diam melalui algoritma simetris AES-256-GCM pada kolom sensitif basis data.
3. Penerbitan dan pemindaian tiket digital berbasis tanda tangan digital asimetris RSA-PSS 2048-bit terintegrasi kode QR untuk kebutuhan check-in mandiri civitas.
4. Laporan hasil pengujian unit otomatis (**Test Execution Report**) yang memvalidasi ketahanan sistem dari kerentanan OWASP Top 10.
5. Penyediaan panduan teknis operasional instalasi server dan panduan pengguna per tingkatan peran.

1.3 Ruang Lingkup Implementasi Nyata

Ekosistem IPB Space rilis akhir mencakup empat domain infrastruktur produksi yang saling terinterkoneksi:



Gambar 1.1: Cetak Biru Arsitektur Jaringan dan Topologi Produksi Cloud Akhir IPB Space.

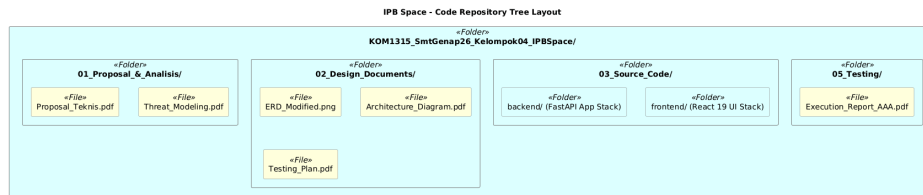
Sesuai dengan bagan topologi cloud pada Gambar 1.1, batasan operasional sistem dikunci pada:

- **FastAPI Backend Container:** Menyediakan REST API utama yang melayani otorisasi, penanganan transaksi sewa, pemeriksaan konflik jadwal asinkron, pembuatan log audit forensik, serta pembubuhan tanda tangan digital tiket menggunakan kunci privat RSA, di-host pada kluster mesin Railway Cloud.
- **React 19 Frontend (Vite 7):** Antarmuka reaktif dinamis yang di-host pada Vercel Edge Network, terintegrasi dengan Axios Client Interceptors untuk rotasi sesi otomatis serta generator tiket digital gambar PNG.
- **PostgreSQL Managed DB Node:** Kluster basis data relasional terisolasi di dalam sub-jaringan privat internal cloud Railway untuk menampung data entitas terenkripsi.

BAB 2: STRUKTUR IMPLEMENTASI DAN TOPOLOGI KODE

2.1 Struktur Kompilasi Repositori Git Akhir

Penyusunan folder direktori pada repositori kerja kelompok akhir ditata secara teratur untuk menyelaraskan arsitektur kode program dengan dokumen spesifikasi rancangan:



Gambar 2.1: Pohon Struktur Direktori Repositori Git Akhir Kelompok 04.

2.2 Arsitektur Modular Komponen Backend (FastAPI App Stack)

Aplikasi server backend dikonfigurasi menggunakan pendekatan pemisahan tanggung jawab berbasis **Repository-Service Pattern** dengan susunan modul sebagai berikut:

- `app/core/`: Menyimpan konfigurasi inisiasi basis data (`database.py`), manajemen penarikan variabel lingkungan (`config.py`), serta fungsionalitas primitif kriptografi biner hashing Bcrypt, sandi blok AES-GCM, dan tanda tangan RSA-PSS (`security.py`).
- `app/models/`: Definisi skema tabel data relasional berbasis SQLAlchemy ORM (`user.py`, `facility.py`, `booking.py`) yang mengimplementasikan polimorfisme untuk pemetaan sub-role aktor.
- `app/schemas/`: Menangani validasi tipe data masuk dan keluar (**Data Transfer Object**) secara ketat menggunakan library Pydantic v2 untuk menyumbat celah eksploitasi parameter.
- `app/services/`: Logika bisnis pusat sistem, mengeksekusi fungsi pemeriksaan irisan waktu irisan ketersediaan jadwal peminjaman ruang secara asinkron.

2.3 Arsitektur Modular Komponen Frontend (React 19 UI Stack)

Aplikasi antarmuka pengguna dirancang menggunakan modularitas berbasis fitur (**Feature-Driven Design**) untuk mengisolasi state komponen:

- `src/context/`: Menyediakan modul `AuthContext . jsx` untuk melacak status persistensi token JWT Bearer, penanganan login multi-peran, serta proses penutupan sesi pada LocalStorage.
- `src/features/bookings/`: Alur formulir dinamis pengajuan peminjaman ruangan, kalender publik interaktif, serta dashboard workspace persetujuan berkas tingkat Manager Fasilitas.
- `src/features/tickets/`: Tampilan manifes tiket digital, modul QR Code generator biner, serta utilitas konversi komponen visual menjadi berkas PNG (`html-to-image`) di sisi klien.
- `src/lib/axios.js`: Konfigurasi instans Axios HTTP Client dengan injector otomatis untuk menyematkan token akses aktif pada header paket data.

BAB 3: IMPLEMENTASI perlindungan DAN PENGENTASAN KEAMANAN SISTEM

Arsitektur sistem pertahanan siber platform IPB Space rilis final diimplementasikan penuh di dalam lapisan kernel logika bisnis aplikasi dengan mengadopsi standarisasi algoritma kriptografi modern berskala industri.

3.1 Kontrol Keamanan Autentikasi (Authentication Layer)

Sistem memvalidasi klaim identitas aktor melalui kombinasi pengerasan kata sandi satu arah dan manajemen sesi bersifat **stateless**:

- **Bcrypt Password Hardening**: Penyimpanan kata sandi plaintext dilarang secara mutlak. Setiap kredensial diubah menjadi string hash memanfaatkan fungsi Blowfish Crypt bersalting dinamis dengan parameter **Cost Factor** dikunci pada skala *12 Putaran* ($2^{12} = 4.096$ iterasi komputasi). Pendekatan overhead waktu ini berhasil melumpuhkan ancaman serangan otomatis **Offline Brute Force**.
- **Stateless JWT Lifecycle Management**: Pasca-keberhasilan login (`LOGIN_SUCCESS`), server menerbitkan sepasang token JSON Web Token (JWT) yang ditandatangani menggunakan kunci rahasia simetris beralgoritma HS256. **Access Token** diatur dengan waktu kedaluwarsa pendek selama 30 menit, sedangkan **Refresh Token** berumur 7 hari disimpan di database dalam format ringkasan hash *SHA-256* untuk memitigasi risiko kebocoran sesi.

3.2 Kontrol Otorisasi dan Pembatasan Hak Akses (Authorization Layer)

Otorisasi hak akses dikontrol ketat di sisi server memanfaatkan fitur **Dependency Injection** FastAPI untuk menegakkan prinsip hak akses minimum (**Least Privilege**) dan pemisahan tugas (**Separation of Duties**):

- **Role-Based Access Control (RBAC Guard)**: Mengisolasi fungsionalitas rute API secara kaku. Jika token civitas mencoba menembak endpoint administratif, rute diputus secara instan di level middleware dengan melempar eksepsi HTTP 403 Forbidden.
- **Insecure Direct Object Reference (IDOR) Mitigation**: Setiap endpoint manipulasi data kritis (seperti fungsi `cancel_booking` dan `check_in_booking`) dibentengi oleh logika **Owner Validation**. Sistem melakukan komparasi biner untuk memastikan `user_id` yang terekstrak dari token JWT aktif identik secara mutlak dengan subjek pemilik record asli di database PostgreSQL.

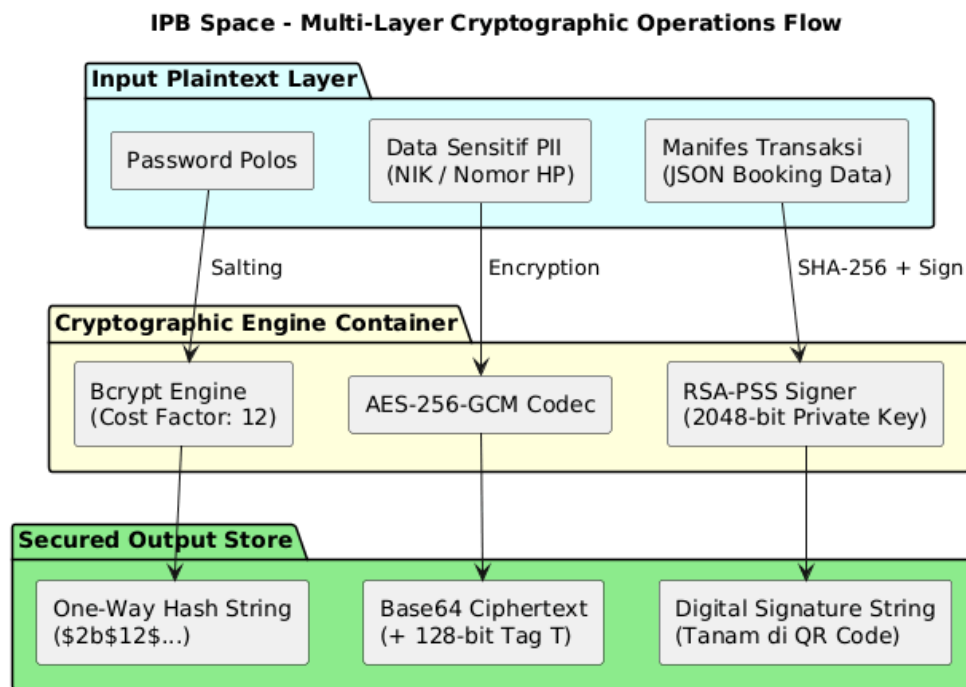
3.3 Protokol Akuntansi dan Audit Forensik (Accounting Layer)

Pemenuhan pilar akuntabilitas birokrasi dilakukan menggunakan arsitektur pencatatan log dua lapis (**Dual-Layer Logging**) terstruktur berbasis pustaka `Structlog`:

1. **Application Activity Log**: Menangkap data makro peristiwa siber secara instan tanpa cache menuju file lokal `app_logs.txt`.
2. **Database Forensics Log**: Mendelegasikan pencatatan parameter mikro forensik (alamat IP asal, string User-Agent gawai, timestamp global standar UTC, dan jenis status request) ke tabel relasional database `login_logs` melalui fitur asinkron **BackgroundTasks** FastAPI. Seluruh rantai baris log diikat menggunakan string unik *UUID v4 Request ID* untuk menjamin sifat log adalah **immutable** (tidak dapat dimanipulasi).

3.4 Perlindungan Data Diam (Data at Rest) dan Tanda Tangan Digital (Digital Signature)

Sebagai pembeda utama, pengerasan data transaksional dan privasi civitas pada platform IPB Space dikunci menggunakan dua algoritma kriptografi terpisah:

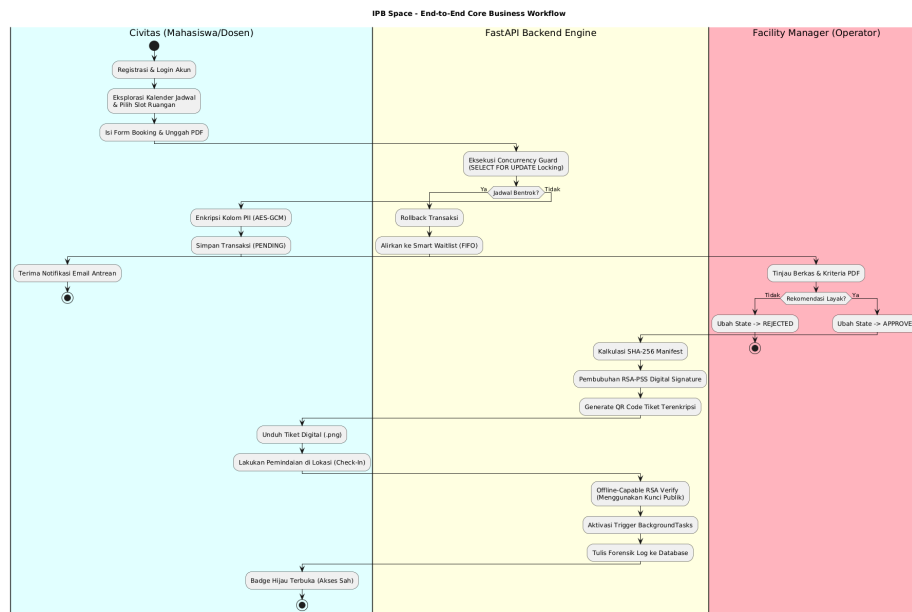


Gambar 3.1: Aliran Data Operasi Kriptografi Berlapis Simetris dan Asimetris IPB Space.

- **Column-Level Encryption (AES-256-GCM):** Sesuai Gambar 3.1, data sensitif berupa Nomor Induk Kependudukan (NIK) dan Nomor HP pada tabel *users* dan *facilities* dienkripsi secara penuh menggunakan sandi blok simetris AES-256 dalam mode **Galois/Counter Mode**. Validasi tag autentikasi 128-bit menjamin bahwa apabila data pada disk dimanipulasi secara ilegal, proses dekripsi server otomatis gagal dan memicu alarm siber.
- **RSASSA-PSS 2048-bit Signature:** Penjaminan anti-penyangkalan (**non-repudiation**) dokumen izin dilakukan menggunakan kunci asimetris. Manifes JSON transaksi diringkas dengan SHA-256 lalu ditandatangani menggunakan Kunci Privat RSA server dengan skema padding probabilistik PSS untuk menerbitkan string tanda tangan digital unik tak terbantahkan yang ditanamkan langsung pada muatan biner QR Code tiket pengguna.

BAB 4: ALUR UTAMA DAN LOGIKA BISNIS APLIKASI

Seluruh modul pengerasan kontrol siber yang telah dirancang diintegrasikan secara melekat ke dalam alur transaksi bisnis utama sistem dari hulu ke hilir:



Gambar 4.1: Diagram Swimlane Runtunan Logika Bisnis Alur Utama Proyek IPB Space.

4.1 Registrasi, Login Multi-Peran, dan Validasi Payload

Berdasarkan visualisasi alur Gambar 4.1, siklus data dimulai ketika aktor Civitas melakukan registrasi identitas mandiri secara formal. Seluruh parameter masukan divalidasi ketat oleh skema model Pydantic di backend FastAPI untuk menyumbat celah eksploitasi parameter. Pasca-autentikasi login sukses, token JWT dikirim kembali menuju browser klien untuk dikunci di dalam LocalStorage secara aman.

4.2 Kalender Jadwal Dinamis dan Penanganan Konflik Konkuren (Concurrency Guard)

Ketika Civitas memilih slot waktu peminjaman ruangan aula pada halaman antarmuka, sistem berhak memproteksi data dari risiko kondisi balapan (**Race Condition**). Sebelum database mengeksekusi penulisan record baru, backend FastAPI melempar kueri interceptor **SELECT FOR UPDATE** untuk mengunci baris data jadwal pada tabel database PostgreSQL. Request tercepat dalam hitungan fraksi milidetik akan berhasil mengunci slot, sedangkan request yang terlambat otomatis dibatalkan (**transaction rollback**) dan dialirkan masuk ke sub-sistem antrean daftar tunggu cerdas (**Smart Waitlist**) berbasis urutan waktu FIFO secara adil.

4.3 Pengajuan Booking, Unggah Berkas, dan Validasi Sandbox Operator

Civitas diwajibkan melampirkan file PDF dokumen surat izin organisasi. File yang masuk disaring ketat melalui fungsi **deep checking MIME-Type** backend untuk menolak ekstensi ilegal samaran penyerang. Berkas yang lolos dikirimkan menuju cloud storage bucket Appwrite menggunakan tautan API Key terisolasi, sementara string alamat lokasi path ditulis ke database dengan state awal berstatus PENDING.

4.4 Otorisasi Persetujuan Berkas dan Penandatanganan Tiket Otomatis

Petugas Facility Manager membuka dashboard workspace admin untuk memeriksa keabsahan file PDF pendukung. Jika dokumen dinyatakan memenuhi kriteria administrasi universitas, operator menekan tombol **Approve**. Aksi ini memicu fungsi **Cryptographic Signer** backend untuk menarik kunci privat RSA-PSS 2048-bit dari environment variable terisolasi, mengomputasi tanda tangan biner manifest transaksi, menuliskan string enkripsi ke database, dan merendernya menjadi objek gambar biner QR Code tiket digital yang siap diunduh dalam format berkas gambar PNG oleh civitas.

4.5 Pemindaian Check-In Lapangan dan Validasi Offline-Capable

Pada hari pelaksanaan agenda di lokasi prasarana fisik kampus, Civitas memperlihatkan tiket digital untuk dipindai oleh gawai terminal petugas keamanan. Sistem validator menjalankan modul **Offline Verification** dengan mendekripsi muatan string QR Code memanfaatkan hanya komponen Kunci Publik RSA server tanpa memicu pemanggilan kueri database relasional pusat, menghemat konsumsi bandwidth infrastruktur. Jika tanda tangan valid, token dinonaktifkan untuk mencegah serangan pemutaran ulang (**replay attack**), dan status check-in sukses terekam secara asinkron ke database.

BAB 5: KETERBATASAN SISTEM DAN REKOMENDASI PENINGKATAN

Meskipun platform IPB Space rilis final telah berhasil membentengi alur kerja utama menggunakan primitif kriptografi modern, kelompok kami mengidentifikasi beberapa parameter keterbatasan arsitektur yang dapat dioptimalkan pada pengembangan tingkat lanjut:

- **Keterbatasan Manajemen Kunci Statis:** Seluruh kunci rahasia global (AES_SECRET_KEY, RSA_PRIVATE_KEY, dan JWT_SECRET_KEY) saat ini masih diisolasi sebagai variabel lingkungan statis di dalam file `.env`. Rekomendasi peningkatan ke depan adalah mengintegrasikan sistem dengan **Key Management Service** (KMS) eksternal seperti HashiCorp Vault atau AWS KMS untuk memfasilitasi rotasi kunci secara otomatis dan berkala tanpa perlu melakukan restart container server backend.
- **Skalabilitas Storage Enkripsi:** Operasi enkripsi biner berkas PDF menggunakan AES-256-GCM dijalankan secara synchronous langsung di dalam memori runtime FastAPI sebelum dialirkan ke Appwrite Storage. Untuk menangani beban pengunggahan berkas berskala massal (ribuan request serentak), sistem disarankan bermigrasi menggunakan arsitektur pemrosesan asinkron berbasis **Message Broker** seperti Redis Queue atau RabbitMQ agar proses komputasi berat kriptografi tidak menyumbat waktu respons API utama.

BAB 6: PANDUAN INSTALASI DAN OPERASIONAL INFRASTRUKTUR

6.1 Prasyarat Minimum Sistem (System Requirements)

Untuk melakukan replikasi dan menjalankan ekosistem IPB Space pada lingkungan lokal pengembangan maupun staging, mesin evaluator wajib memenuhi spesifikasi berikut:

- **Runtime Environment:** Python 3.10 atau versi di atasnya (Backend Engine) dan Node.js v18+ dilengkapi dengan paket pengelola npm (Frontend Engine).
- **Database Server:** PostgreSQL v16 Relational Engine.
- **Containerization:** Docker Engine beserta Docker Compose CLI (Sangat direkomendasikan).

6.2 Menjalankan Aplikasi via Docker Container (Direkomendasikan)

Untuk mempermudah proses deployment secara otomatis dan terisolasi, jalankan runtunan perintah berikut pada terminal root proyek:

```
cd 03_Source_Code/backend
```

Menyalakan kluster database dan backend server terisolasi

```
docker-compose up db -d
```

```
docker-compose up ipb-space-backend --build -d
```